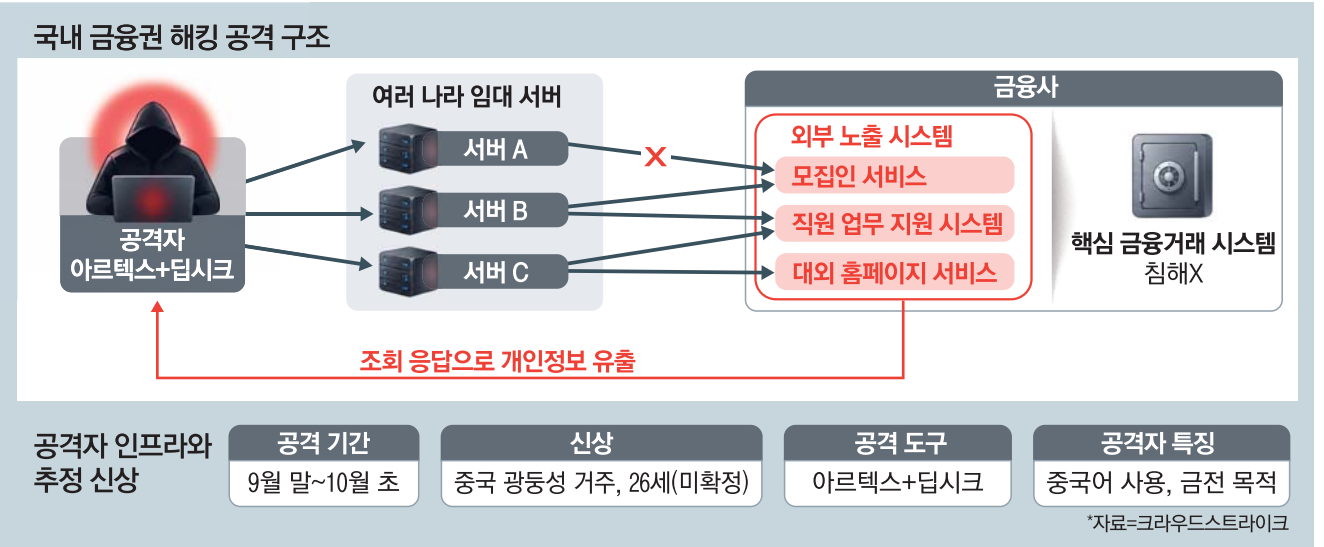
“韓 금융권 해킹범, 중국 거주 26세 추정”

글로벌 사이버 보안 기업 크라우드스트라이크 분석

클로드 사용기록서 단서 확인
이력서 작성 중 신상정보 노출
회사 측 “신원 확정은 아직”

실제 침투엔 中 딥시크 동원



최근 국내 금융권을 공격한 해커가 중국 광둥성에 사는 26세 인물일 수 있다는 분석이 나왔다. 공격자가 인공지능(AI) 코딩 도구에 이력서를 써달라며 입력한 신상 정보가 단서가 됐다. 그는 중국산 AI 해킹 자동화 도구로 금융사 외곽 시스템의 빈틈을 파고든 것으로 분석됐다.

글로벌 사이버 보안 기업 크라우드스트라이크가 7일(현지시간) 공개한 보고서에서 “공격자가 앤트로픽의 ‘클로드 코드’에 보안 연구원 이력서를 요청하며 한국 금융사를 상대로 한 공격 결과를 경력으로 넣어달라고 했다”고 밝혔다. 이 과정에서 영문 이름 이니셜과 전화번호, 텔레그램 계정, 학력(화난이공대), 거주지(광둥성 마오밍)가 입력됐다. 다만 처음 기입한 생년월일에 따르면 2007년생으로, 적어 낸 나이와 맞지 않는다. 크라우드스트라이크는 “해당 정보가 공격자 본인 것일 가능성이 높지만, 신원을 확정할 수 없다”고 단서를 달았다.

◆공격자 공개 폴더서 신상 노출

신상 단서는 공격자가 관리하던 서버에서 나왔다. 크라우드스트라이크는 인증 없이 누구나 볼 수 있게 열려 있던 서버의 공개 폴더에서 클로드 코드 작업 기록과 메모리 파일, 해킹 도구 설정 파일을 확보했다. 한국 금융사 침투와 연관된 서버의 문서에 적힌 홍콩 인터넷프로토콜(IP)을 추적한 결과다. 크라우드스트라이크는 “홍콩 서버가 주 거점 역할을 하고, 별도 서버가 한국 공격을 수행한 것으로 추정되는 이중 구조”라고 분석했다. 작업 기록에는 한국에서 유출된 데이터가 주로 어디에서 거래되는지 묻고, 관련 정보를 파는 텔레그램 그룹을 찾아달라고 요청한 내용도 있었다.

한국 금융사 침입에는 중국에서 개발된 오픈소스 에이전틱 침투 테스트 도구 ‘아르텍스(ARTEX)’가 쓰였다. AI가 스스로 취약점을 찾고 공격까지 시도하도록 자동화한 프로그램이다. 공격자가 운용한 아르텍스는 중국 딥시크의 ‘V4.1-플래시’를 주력 모델로 썼다. 클로드 코드 작업 일부에는 중국 즈푸AI의 ‘GLM-5.3’, 미국 스페이스XAI의 ‘그록 4.6’도 보조로 활용됐다. 크라우드스트라이크는 공격자를 금전적 동기를 가진 중국어 사용자로 추정했다.

◆핵심 시스템 아닌 외곽 뚫려

해커의 신상 단서가 열어둔 서버에서 드러났다면, 금융사가 뚫린 이유 역시 기본 보안의 빈틈이었다는 분석이 나왔다. SK쉴더스는 8일 공개한 보고서에서 이번 사태를 “AI가 새로운 취약점을 만든 해킹이 아니라 금융사가 방치한 외곽 시스템의 허점을 기계의 속도로 파고든 공격”이라고 규정했다.

SK쉴더스는 아르텍스의 작동 방식도 뜯어봤다. 계획을 담당하는 AI 에이전트가 다음 행동을 정하면 여러 실행 에이전트가 표적과 경로별로 동시에 점검하고 결과를 공유한다. 계획 에이전트는 도출된 결과를 바탕으로 대응 방향을 다시 정하며 점검을 반복한다. SK쉴더스는 “이런 구조가 공격자의 단계별 개입 부담을 줄이고 공격 속도와 범위를 키울 수 있다”고 설명했다. 침해 경로는 대출모집인 조회나 직원 업무 지원처럼 외부에 노출된 작업보조 시스템이었고, 핵심 금융거래 시스템의 피해는 확인되지 않았다.

애덤 마이어스 크라우드스트라이크 공격 대응 작전 총괄은 “해커들이 에이전틱 AI 도구와 기존 침투 기법을 결합해 공격 속도를 높이고 규모를 키우는 방향으로 진화하고 있다”고 분석했다.

고민서 기자